

[SOC Analyst Fundamentals Notes]

[1. Daily Duties of a SOC Analyst]

[What You Do as a SOC Analyst]

- Detect and prevent a data stealer infection on a coworker's laptop.
- Analyze and stop a phishing campaign targeting the finance team.
- Participate in a bigger incident, such as a full-scale ransomware attack.
- Team up with your teammates to build detection rules and automations.
- Go beyond cyber and understand how companies operate from the inside.

[Core Responsibilities]

As a Tier-1 SOC Analyst, you are the first responder. You monitor, triage, escalate, and document every security alert.

- Monitor SIEM, EDR/XDR, firewall, and email alerts.
- Validate alerts: Differentiate between **True Positive** vs. **False Positive**.
- Escalate critical events to Tier-2 / Incident Response (IR) teams.
- Log everything carefully inside ticketing systems.

Escalation Path:

[L1 Analyst] → [L2 Analyst] → [L3 Analyst] → [Incident Response] → [Threat Hunter]

[What is a SOC?]

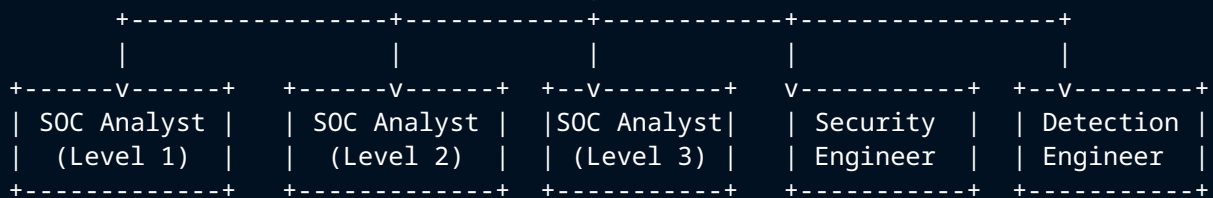
A SOC (Security Operations Center) is a dedicated facility operated by a specialized security team. This team aims to continuously monitor an organization's network and resources and identify suspicious activity to prevent damage. This team works 24 hours a day, seven days a week.

[2. The Core Pillars of a SOC]

Core Concept: People, Process, and Technology coexist in a SOC environment. A team of professional individuals working on state-of-the-art security tools in the presence of proper processes is what makes a mature SOC environment. The main focus of the SOC team is to keep Detection and Response intact.

[Pillar 1: People (The SOC Team Structure)]

```
+-----+
|      CISO      |
+-----+-----+
|                 |
+-----v-----+
|   SOC Manager   |
+-----+-----+
```



(Image Credit: tryhackme.com)

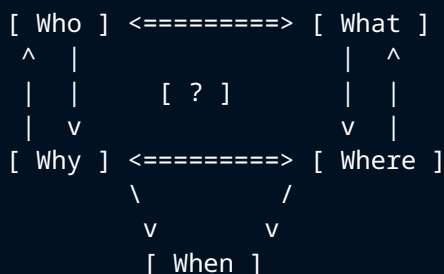
[Roles & Responsibilities]

- **SOC Analyst (Level 1):** Anything detected by the security solution passes through these analysts first. They are the first responders to any detection. They perform basic alert triage to determine if a specific detection is harmful and report them through proper channels.
- **SOC Analyst (Level 2):** Detections that require deeper investigation are escalated here. Level 2 Analysts dive deeper into investigations and correlate data from multiple sources to perform a proper analysis.
- **SOC Analyst (Level 3):** Experienced professionals who proactively look for threat indicators (Threat Hunting) and support incident response activities. Critical severity detections are passed to them for detailed responses, including containment, eradication, and recovery.
- **Security Engineer:** Deploys, configures, and maintains the security solutions and tools to ensure their smooth operation for the analyst team.
- **Detection Engineer:** Focuses on building the logic and security rules behind security solutions to detect harmful activities. (Level 2 and 3 analysts often create these rules, but some teams utilize an independent detection engineer).
- **SOC Manager:** Manages the operational processes followed by the team, provides tactical support, and maintains direct contact with the organization's **CISO (Chief Information Security Officer)** to provide security posture updates.

[3. Pillar 2: Process (Alert Triage & Reporting)]

[Alert Triage]

The alert triage is the basis of the SOC team. The first response to any alert is to perform a proper triage using the **5 Ws framework** to understand the true nature of the event.



[Triage Scenario Example: Malware Detected on Host "GEORGE PC"]

- **What?** A malicious file was detected on one of the hosts inside the organization's network.
- **When?** The file was detected at 13:20 on June 5, 2024.
- **Where?** The file was detected in the directory of the host: "GEORGE PC".
- **Who?** The file was detected for the user George.

- **Why?** After the investigation, it was found that the file was downloaded from a pirated software-selling website. The investigation with the user revealed that they downloaded the file as they wanted to use software for free.

[Reporting & Escalation]

- Detected harmful alerts need to be escalated to higher-level analysts for a timely response and resolution.
- These alerts are escalated as tickets and assigned to the relevant people.
- The report should discuss all the 5 Ws along with a thorough analysis, and screenshots should be used as evidence of the activity.

[Incident Response and Forensics]

Sometimes, reported detections point to critical, highly malicious activities. In these scenarios, high-level teams initiate an incident response. A detailed forensics activity is often performed to determine the root cause of the incident.

[4. Pillar 3: Technology (Security Solutions)]

Having the right People and Processes in place would never be enough without security solutions for detection and response. The Technology portion refers to the security tools that efficiently minimize the SOC team's manual effort to detect and respond to threats.

[Core Security Solutions]

- **SIEM (Security Information and Event Management):** A popular tool used in almost every SOC. It collects logs from various network devices (log sources). Detection rules are configured in the SIEM with logic to identify suspicious activity. The SIEM correlates data across multiple sources and alerts analysts in case of a rule match. Modern SIEMs also provide user behavior analytics, threat intelligence, and machine learning algorithms.

Note: The SIEM solution only provides the **Detection** capabilities in a SOC environment.

- **EDR (Endpoint Detection and Response):** Provides the SOC team with detailed real-time and historical visibility of device activities. It operates at the endpoint level, carries out automated responses, and allows analysts to investigate and respond to threats with a few clicks.
- **Firewall:** Functions purely for network security and acts as a barrier between your internal and external networks (such as the Internet). It monitors and filters incoming/outgoing network traffic, blocking unauthorized traffic before it reaches the internal network.

Other common tools deployed based on threat surface and resources include: **Antivirus**, **EPP (Endpoint Protection Platform)**, **IDS/IPS**, **XDR (Extended Detection and Response)**, and **SOAR (Security Orchestration, Automation, and Response)**.

[5. Corporate Security Environments & Teams]

[Department Variations]

- **Tiny Companies:** The standard IT department takes on the role of securing the company.
- **Small to Medium Companies:** A generic "Information Security" team handles all sorts of mixed security tasks.
- **Bigger Companies:** A CISO oversees multiple dedicated security teams, each handling a specific task.

[Core Security Teams]

- **Red Team:** Offensive security experts, penetration testers, or ethical hackers who actively look for security issues.
- **GRC Team:** Governance, Risk, and Compliance specialists managing organizational policies and ensuring compliance with regulations like PCI DSS.
- **Blue Team:** Defensive security experts like SOC analysts, engineers, or incident responders.

[The Specialized "Firefighters" (CIRT / CSIRT / CERT)]

If SOC expertise is not enough or an incident goes completely out of control, you urgently call the Cyber Incident Response Team (CIRT). These members possess broad knowledge of cyber threats and handle severe breaches independently without relying heavily on tools like EDR or SIEM.

[Managed Security Services Provider (MSSP)]

Not every organization has the expertise to operate an in-house SOC, so they rely on an MSSP—a company that delivers outsourced security services (most commonly SOC monitoring) to its clients. Working at an MSSP is typically high-pressure, but it is an excellent option to quickstart your career.

[6. Human Attack Vectors & Defense]

[Why Humans Are Targeted]

Humans are targeted because of the access they provide to protected assets like websites, mailboxes, or databases. Some threat actors hunt for a specific access, while others breach as many accounts as possible and decide how to exploit them later.

[Social Engineering Tactics]

Attacks targeting humans rely on manipulating the victim into helping the attacker, exploiting human psychology rather than technical flaws. To succeed, these attacks are designed to be:

- **Trustworthy:** The attacker appears legitimate so the victim trusts them.
- **Emotional:** The attack triggers strong feelings like urgency, fear, or curiosity.

[Common Human Delivery Vectors]

- Phishing Attacks
- Malicious Software/Malware Downloads
- Deep Fakes
- Impersonation
- Other attacks like Keylogging, Physical attacks, etc.

[How To Defend Humans]

Defending against human-centric threats involves two key tasks:

1. **Mitigation:** Aims to prevent or reduce the chance and impact of attacks (e.g., employee training or deploying a robust anti-phishing solution).
2. **Detection:** The primary task of a SOC analyst. Over time, manual mitigation becomes tiring, which is why organizations deploy the SOC suite of automated solutions.

[Key Defense Solutions Checklist]

- Anti-phishing solution
- Antivirus / EDR solution
- Implementation of the "Trust but verify" principle
- Regular Security Awareness Training